

Money Card — M0 Shared System Contract V10 Master Endpoint Inventory

Authoritative Complete API Inventory for Developer 2 Backend Handover (Frozen V1)

Standard Response Envelopes

Success Envelope

```
{
  "success": true,
  "data": {}
}
```

Error Envelope

```
{
  "success": false,
  "error": {
    "code": "ERROR_CODE",
    "message": "Human readable description of the error."
  }
}
```

Paginated List Envelope

```
{
  "success": true,
  "data": {
    "items": [],
    "pagination": {
      "page": 1,
      "limit": 20,
      "total": 0,
      "totalPages": 0
    }
  }
}
```

1. Authentication Endpoints

1.1 POST /api/v1/auth/login

- **Purpose:** Authenticate Super Admin, Org Admin, or Staff.
- **Authentication:** Public
- **Permission:** None
- **Scope:** Identity determined by credentials
- **Request Body:**

```
{
  "email": "staff@example.com",
  "password": "password"
}
```

- **Success Status:** 200 OK
- **Success Response:**

```
{
  "success": true,
  "data": {
    "accessToken": "jwt_access_token_value",
    "user": {
      "id": "staff_001",

```

```

    "name": "John Doe",
    "email": "staff@example.com",
    "role": "STAFF",
    "organizationId": "org_001",
    "permissions": ["CARD_VIEW", "CARD_ISSUE", "RECHARGE", "PURCHASE", "REFUND"],
    "assignedBranchIds": ["branch_001"]
  }
}

```

- **Possible Errors:** [400 VALIDATION_ERROR](#), [401 UNAUTHORIZED](#)
- **Idempotency:** Do not duplicate active session unexpectedly
- **Side Effects:** Create/rotate refresh session; audit login event.

1.2 POST /api/v1/auth/refresh

- **Purpose:** Rotate refresh session and issue a new access token.
- **Authentication:** Refresh credential (HttpOnly cookie for Web; secure storage for Flutter)
- **Permission:** None
- **Scope:** Authenticated refresh session
- **Request Body:** `{}` or cookie context
- **Success Status:** [200 OK](#)
- **Success Response:**

```

{
  "success": true,
  "data": {
    "accessToken": "new_jwt_access_token_value"
  }
}

```

- **Possible Errors:** [401 UNAUTHORIZED](#)
- **Idempotency:** Idempotent-safe rotation
- **Side Effects:** Rotate refresh token; invalidate previous token/session.

1.3 POST /api/v1/auth/logout

- **Purpose:** Revoke refresh session and sign out.
- **Authentication:** Access + refresh context
- **Permission:** None
- **Scope:** Current identity
- **Request Body:** `{}`
- **Success Status:** [200 OK](#)
- **Success Response:**

```

{
  "success": true,
  "data": {
    "loggedOut": true
  }
}

```

- **Possible Errors:** [401 UNAUTHORIZED](#)
- **Idempotency:** Repeated logout safe
- **Side Effects:** Revoke refresh session and invalidate tokens.

1.4 GET /api/v1/auth/me

- **Purpose:** Return current identity, organization, permissions, and assigned branches.
- **Authentication:** Access token
- **Permission:** None
- **Scope:** Current identity

- **Success Status:** 200 OK

- **Success Response:**

```
{
  "success": true,
  "data": {
    "user": {
      "id": "staff_001",
      "name": "John Doe",
      "email": "staff@example.com",
      "role": "STAFF",
      "organizationId": "org_001",
      "permissions": ["CARD_VIEW", "CARD_ISSUE", "RECHARGE", "PURCHASE", "REFUND"],
      "assignedBranchIds": ["branch_001"]
    },
    "organization": {
      "id": "org_001",
      "name": "Acme Cafeteria Group",
      "status": "ACTIVE"
    },
    "permissions": ["CARD_VIEW", "CARD_ISSUE", "RECHARGE", "PURCHASE", "REFUND"],
    "branches": [
      {
        "id": "branch_001",
        "name": "Main Cafeteria",
        "organizationId": "org_001",
        "status": "ACTIVE"
      }
    ]
  }
}
```

- **Possible Errors:** 401 UNAUTHORIZED

- **Idempotency:** N/A (Read-only)

1.5 POST /api/v1/auth/forgot-password

- **Purpose:** Start password reset without revealing account existence (M0 Rule 14.3).

- **Authentication:** Public

- **Permission:** None

- **Scope:** Account lookup

- **Request Body:**

```
{
  "email": "user@example.com"
}
```

- **Success Status:** 200 OK

- **Success Response:**

```
{
  "success": true,
  "data": {
    "message": "If the account exists, reset instructions were sent."
  }
}
```

- **Possible Errors:** 400 VALIDATION_ERROR

- **Idempotency:** Repeated requests must not reveal existence

- **Side Effects:** Create one-time time-limited reset token.

1.6 POST /api/v1/auth/reset-password

- **Purpose:** Consume reset token and set new password.

- **Authentication:** Reset token

- **Permission:** None

- **Scope:** Token-scoped

- **Request Body:**

```
{
  "token": "reset_token_xyz",
  "newPassword": "newSecurePassword123"
}
```

- **Success Status:** 200 OK

- **Success Response:**

```
{
  "success": true,
  "data": {
    "reset": true
  }
}
```

- **Possible Errors:** 400 VALIDATION_ERROR, 401 UNAUTHORIZED

- **Idempotency:** Token one-time

- **Side Effects:** Invalidate reset token; update password hash.

1.7 POST /api/v1/auth/change-password

- **Purpose:** Change authenticated password.

- **Authentication:** Access token

- **Permission:** None

- **Scope:** Current identity

- **Request Body:**

```
{
  "currentPassword": "oldPassword123",
  "newPassword": "newSecurePassword123"
}
```

- **Success Status:** 200 OK

- **Success Response:**

```
{
  "success": true,
  "data": {
    "changed": true
  }
}
```

- **Possible Errors:** 400 VALIDATION_ERROR, 401 UNAUTHORIZED

- **Idempotency:** Repeated call requires current credentials

- **Side Effects:** Update password hash; revoke other sessions.

2. Super Admin Endpoints

2.1 Organizations

- **GET /api/v1/admin/organizations:** List all organizations on the platform. Auth: SUPER_ADMIN. Query: page, limit, search, status, sortBy, sortOrder. Returns paginated organization items.
- **POST /api/v1/admin/organizations:** Create organization. Auth: SUPER_ADMIN. Body: {"name": "Acme Cafeteria", "status": "ACTIVE"}. Returns 201 Created with organization details.
- **GET /api/v1/admin/organizations/:id:** Get organization detail with effective limits and active subscription. Auth: SUPER_ADMIN. Returns organization record.
- **PATCH /api/v1/admin/organizations/:id:** Update organization name or status (ACTIVE | INACTIVE | SUSPENDED). Auth: SUPER_ADMIN.

2.2 Global Plans (Catalog)

- **GET /api/v1/admin/plans:** List platform global plans. Auth: SUPER_ADMIN. Query: page, limit, status.
- **POST /api/v1/admin/plans:** Create new global plan template. Auth: SUPER_ADMIN. Body contains name, price, currency, billingInterval, branchLimit, staffLimit, cardLimit, inventoryLevel, reportsLevel,

analyticsLevel, multiBranchEnabled, whiteLabelEnabled, supportLevel. **Note:** transactionLimit is absent in V10.

- GET /api/v1/admin/plans/:id: Get global plan details. Auth: SUPER_ADMIN.
- PATCH /api/v1/admin/plans/:id: Edit global plan template. Auth: SUPER_ADMIN. Updates defaults without altering org overrides.

2.3 Organization Plan Assignment & Overrides

- GET /api/v1/admin/organizations/:id/subscription: Get current subscription and effective limits for target organization. Auth: SUPER_ADMIN.
- PATCH /api/v1/admin/organizations/:id/subscription: Assign or change an organization's plan and status. Body: {"planId": "PLAN_PRO", "status": "ACTIVE", "startDate": "...", "renewalDate": "..."}.
- GET /api/v1/admin/organizations/:id/limit-overrides: Get custom limits for target organization.
- PATCH /api/v1/admin/organizations/:id/limit-overrides: Set custom limits (staffLimit, branchLimit, cardLimit). Upserts OrganizationSubscriptionLimitOverride.

2.4 Subscriptions & Billing

- GET /api/v1/admin/subscriptions: List organization subscriptions. Query: page, limit, organizationId, planId, status.
- GET /api/v1/admin/subscriptions/:id: Get subscription detail with payments and overrides.
- GET /api/v1/admin/subscription-payments: List subscription direct payment history records. Query: page, limit, organizationId, status.

2.5 Plan Change Requests

- GET /api/v1/admin/plan-change-requests: List requests from organizations. Query: page, limit, status, organizationId, requestType.
- GET /api/v1/admin/plan-change-requests/:id: Get plan-change request details.
- PATCH /api/v1/admin/plan-change-requests/:id: Approve, reject, or cancel a request. Body: {"status": "APPROVED", "adminNote": "..."}.

3. Organization Admin & Scope Endpoints

3.1 Organization Profile

- GET /api/v1/organization: Get current authenticated organization profile, active subscription, and effective limits. Auth: ORG_ADMIN.
- PATCH /api/v1/organization: Update organization profile details/settings. Auth: ORG_ADMIN. Body: {"name": "..."}.

3.2 Branches

- GET /api/v1/branches: List accessible branches. Auth: ORG_ADMIN or BRANCH_VIEW. Query: page, limit, search, status, sortBy, sortOrder.
- POST /api/v1/branches: Create branch within current organization. Auth: ORG_ADMIN or BRANCH_MANAGE. Checks effective branch limit.
- GET /api/v1/branches/:id: Get branch detail. Auth: ORG_ADMIN or BRANCH_VIEW.
- PATCH /api/v1/branches/:id: Edit branch name or status. Auth: ORG_ADMIN or BRANCH_MANAGE.

3.3 Staff Management

- GET /api/v1/staff: List staff accounts. Auth: ORG_ADMIN or STAFF_VIEW. Query: page, limit, search, status, branchId.
- POST /api/v1/staff: Create staff member with permissions and branch assignments. Auth: ORG_ADMIN or STAFF_MANAGE. Body: {"name": "...", "email": "...", "permissions": ["CARD_VIEW"], "branchIds": ["branch_001"]}.
- GET /api/v1/staff/:id: Get staff details including assigned branches and permissions. Auth: ORG_ADMIN or STAFF_VIEW.

- PATCH /api/v1/staff/:id: Edit staff profile details or status. Auth: **ORG_ADMIN** or **STAFF_MANAGE**.
- PUT /api/v1/staff/:id/branches: Atomically replace staff branch assignments. Body: {"branchIds": ["branch_001", "branch_002"]}
- PUT /api/v1/staff/:id/permissions: Atomically replace staff permissions. Body: {"permissions": ["CARD_VIEW", "PURCHASE"]}

3.4 Permissions Catalog

- GET /api/v1/permissions: List frozen 20-permission catalog defined in M0 Section 1.1. Auth: Authenticated Admin / Staff.

4. Cards & Card Sessions Endpoints

4.1 Cards

- GET /api/v1/cards: List cards with filters (page, limit, search, status, branchId). Auth: **CARD_VIEW** or **ORG_ADMIN**.
- POST /api/v1/cards: Create/issue a card manually. Body: {"physicalCardNumber": "MC-001", "branchId": "branch_001"}. Auth: **CARD_ISSUE** or **ORG_ADMIN**. Generates secure random opaque QR token. Initial state **AVAILABLE**.
- GET /api/v1/cards/:id: Get card details and audit summary. Auth: **CARD_VIEW** or **ORG_ADMIN**.
- POST /api/v1/cards/resolve: Resolve card by QR token for Staff workflow. Body: {"qrToken": "opaque_token"}. Auth: **CARD_VIEW**. Returns safe card resolution data.
- POST /api/v1/cards/:id/block: Block card. Body: {"reason": "..."}. Auth: **CARD_BLOCK** or **ORG_ADMIN**. Card state becomes **BLOCKED**.
- POST /api/v1/cards/:id/unblock: Unblock card. Auth: **CARD_UNBLOCK** or **ORG_ADMIN**. Card state becomes **AVAILABLE**.
- POST /api/v1/cards/import: Bulk import cards from CSV file for target branch. Auth: **ORG_ADMIN** or **CARD_ISSUE**. Multipart: file + branchId.
- GET /api/v1/cards/import/template: Download card import CSV template.

4.2 Card Sessions & Financials

- POST /api/v1/card-sessions: Create **ACTIVE** session for **AVAILABLE** card. Body: {"cardId": "CARD001", "branchId": "BRANCH001"}. Auth: **CARD_ISSUE**. Initial balance 0. Card transitions **AVAILABLE** -> **ACTIVE**.
- GET /api/v1/card-sessions: List card sessions for monitoring. Auth: **ORG_ADMIN** or **SESSION_VIEW**. Query: page, limit, search, status, cardStatus, sessionStatus, branchId, dateFrom, dateTo.
- GET /api/v1/card-sessions/:id: Get session detail with transaction ledger. Auth: **ORG_ADMIN** or **SESSION_VIEW**.
- POST /api/v1/card-sessions/:id/recharge: Recharge active session. Auth: **RECHARGE**. Body: {"amount": 500, "paymentMethod": "CASH|"UPI", "externalReference": "optional"}. Creates payment, transaction, and credits balance atomically.
- POST /api/v1/card-sessions/:id/purchase: Purchase products from active session. Auth: **PURCHASE**. Body: {"items": [{"productId": "PRODUCT001", "quantity": 1}]}.
- POST /api/v1/card-sessions/:id/return: Return/settle session. Auth: **CARD_RETURN**. Refunds remaining balance; settles session to balance 0; card returns to **AVAILABLE**.
- POST /api/v1/card-sessions/:id/refund: Explicit refund/settlement endpoint if retained. Auth: **REFUND**.

5. Products & Inventory Endpoints

5.1 Products

- GET /api/v1/products: List products. Auth: **PRODUCT_VIEW** or **ORG_ADMIN**. Query: page, limit, search, status, branchId, category.
- POST /api/v1/products: Create product with multi-select category array. Auth: **PRODUCT_MANAGE** or **ORG_ADMIN**. Body: {"branchId": "branch_001", "itemName": "Veg Burger", "category": ["Veg", "Fast Food"], "price": 120, "status": "ACTIVE"}. **Tags removed.**

- GET /api/v1/products/:id: Get product detail. Auth: **PRODUCT_VIEW** or **ORG_ADMIN**.
- PATCH /api/v1/products/:id: Update product. Auth: **PRODUCT_MANAGE** or **ORG_ADMIN**.

5.2 Inventory & CSV Import

- GET /api/v1/inventory: List stock records. Auth: **INVENTORY_VIEW** or **ORG_ADMIN**. Query: **page, limit, search, status, branchId, productId**.
- PATCH /api/v1/inventory/:id: Adjust stock quantity. Auth: **INVENTORY_MANAGE** or **ORG_ADMIN**. Body: {"quantity": 100, "reason": "Stock adjustment"}.
- POST /api/v1/inventory/import: 2-stage CSV import workflow (Upload/Validate/Preview -> Confirm/Commit). Auth: **INVENTORY_IMPORT** or **ORG_ADMIN**. Multipart: **file + branchId**. Schema: **itemName, category, price**. All-or-nothing atomic commit.
- GET /api/v1/inventory/import/template: Download 3-column CSV template (**itemName, category, price**).

6. Analytics & Reports Endpoints

6.1 Analytics

- GET /api/v1/analytics: Preview analytics dataset. Auth: **VIEW_ANALYTICS** or authorized **ORG_ADMIN/SUPER_ADMIN**. Query: **dateFrom, dateTo, branchId, metric, groupBy, filters**.
- GET /api/v1/analytics/export: Export exact analytics dataset as PDF. Auth: Same as preview. Query: **format=pdf** + identical preview filter parameters.

6.2 Reports

- GET /api/v1/reports: List available formal reports. Auth: **VIEW_REPORTS** or authorized **ORG_ADMIN/SUPER_ADMIN**. Query: **type, dateFrom, dateTo, branchId, page, limit**.
- GET /api/v1/reports/:id/pdf: Download formal report as PDF. **PDF only in V10**.

7. Organization Subscriptions & Plan Change Requests

- GET /api/v1/plans: List comparison plans visible to Org Admin. Auth: **ORG_ADMIN**.
- GET /api/v1/subscription: Get current organization subscription, plan details, effective limits, and usage metrics. Auth: **ORG_ADMIN**.
- GET /api/v1/subscription/payments: Get organization subscription billing history. Auth: **ORG_ADMIN**. Query: **page, limit, status**.
- GET /api/v1/subscription/payments/:id: Get single subscription payment record. Auth: **ORG_ADMIN**.
- POST /api/v1/plan-change-requests: Submit Contact Super Admin plan-change request. Auth: **ORG_ADMIN**. Body: {"requestedPlanId": "PLAN_PRO", "requestType": "UPGRADE"|"DOWNGRADE"|"ENTERPRISE", "message": "..."}.
- GET /api/v1/plan-change-requests: List own organization plan-change requests. Auth: **ORG_ADMIN**. Query: **page, limit, status**.
- GET /api/v1/plan-change-requests/:id: Get single plan-change request. Auth: **ORG_ADMIN**.

8. Public User Portal Endpoints

- POST /api/v1/public/cards/resolve: Resolve public QR card token. Authentication: Public. Body: {"qrToken": "opaque_card_token"}. Returns safe card/session eligibility.
- POST /api/v1/public/sessions/access: Generate a dedicated, revocable **sessionToken** for an eligible active Card Session. Authentication: Public card context. Body: {"cardToken": "opaque_card_token"}. Returns {"sessionToken": "...", "expiresAt": "..."}.
- GET /api/v1/public/sessions/:sessionToken: Get current active session details (balance, branch display name, status, timestamps). Authentication: Portal session token.

- [GET /api/v1/public/sessions/:sessionToken/transactions](#): Get transaction ledger for the current session.
Authentication: Portal session token. Query: [page](#), [limit](#), [type](#), [status](#).
- [GET /api/v1/public/sessions/:sessionToken/receipts](#): Get receipts for purchases in the current session.
Authentication: Portal session token. Query: [page](#), [limit](#).